执行摘要

HyperOS 预装运营商 DM 组件数据采集与上报

- **对象**：一台 Xiaomi HyperOS 3.0（Android 16）设备
- **方法**：静态反编译 + 运行时数据库取证 + 真机抓包 + 解密验证
- **日期**：2026-11-05

结论

设备上存在 **两套运营商终端管理（DM）客户端、一套系统遥测组件** 和 **一套本地反诈数据库**。两套 DM 都在采集设备与位置信息并向外上报；反诈数据库只写本地，未发现上传。

关键发现

#	发现
1	联通 DM `com.mobiletools.systemhelper` 经 **明文 HTTP 18080** 上报设备/SIM 标识、经纬度、基站、WiFi 与 App 清单
2	移动 DM `com.miui.dmregservice` 经 HTTPS 443 上报 App 清单、完整 IMSI/ICCID、基站/WiFi、流量（含路由器 MAC 与公网 IP）
3	加密为 `AES-128-ECB`，**`key = MD5(明文)`**；`sign` 是 RSA-1024 包裹的 key
4	两套 DM 均有 **无权限保护的导出组件**，本机任意应用可重定向服务器或触发上报
5	反诈库（截屏时间/安装/通话）仅本地；AI 通话防诈开关关闭
6	AI 防诈录屏**仅微信/QQ 通话触发**；一旦触发为全屏镜像 720p → `clip.mp4` 上传，但开关 0、`RECORD_AUDIO` 未授权、无活跃 MediaProjection；截图仅记时间戳

实测结果

- 成功抓包并解密：**B（设备信息）**、**R（信号历史，100 条）**、**A（App 清单，169 个）**

- 服务器限流：同一时段 `200` 与 `429` 混合；相同明文重试密文完全一致，且被接受（无防重放）
- 两套 DM 的待传队列、预装清单、基站/流量数据均已在本地取到
- 远程无法实时触发：两套 DM 均无 push/网络监听；触发源只有闹钟、系统广播、本地导出组件、运营商短信/STK（间接）
- 采集与上报频率不同：位置/基站每 **30 分钟**写入本地；信号历史默认 **12 小时**、App 清单 **24 小时**上报一次
- `com.miui.dmregservice` 已整包禁用，重启后仍禁用、无闹钟、无流量

风险与建议

维度	评级	建议
隐私采集	高	关闭 `operator_service_improve_plan`；清理队列；按需禁用两个包
传输安全	中高	厂商改用 HTTPS + AEAD，停止 `key=MD5(明文)`，RSA ⩾ 2048
用户可控性	低	提供可见开关、数据清单与删除入口
本地攻击面	中	导出组件增加签名权限与调用方校验

> 用户侧一条命令即可关闭联通 DM 总闸： `settings put secure operator_service_improve_plan 0` 注意：该开关**只控制联通 DM**，移动 DM 由云端开关单独控制。
>
> 移动 DM 需整包禁用：`pm disable-user --user 0 com.miui.dmregservice`。 实测：禁用后进程不启动、无 443/5683 流量，**重启后仍禁用、无闹钟、不复活**。

证据

- 公开报告：`docs/report_public.md`（15 页）
- 证据清单：`evidence/MANIFEST.md`（SHA-256）

- 抓包：仅本地 `private/pcap/`（不入库）；反编译关键类：`evidence/decompiled/key/`

声明

本报告基于单台设备、单次取证；组件均为系统预装、Xiaomi 平台签名。报告关注采集范围、加密方式与用户可控性，不推断其主观意图。